

Internal Security Audit: Controls and Compliance Assessment

Simulated Case Study — Botium Toys

Security Controls Assessment

Audit Summary

An internal security audit was conducted to evaluate the organization's existing security controls and its alignment with selected compliance best practices. The source risk assessment assigns an overall risk score of 8 out of 10, citing gaps in asset management, security controls, and compliance practices.

This assessment reviews the organization's technical, administrative, and physical controls and identifies areas that require remediation to reduce security and business risk.

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance Best-Practice Assessment

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organization Controls (SOC Type 1, SOC Type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate,

and has been validated.

- ☐ ☒ Data is available to individuals authorized to access it.
-

Key Findings

The assessment identified several existing security controls, including firewall protection, antivirus software, physical locks, CCTV surveillance, and fire detection and prevention systems.

Significant control gaps remain in least privilege, separation of duties, disaster recovery planning, critical-data backups, intrusion detection, encryption, password management, and scheduled maintenance procedures for legacy systems.

The PCI DSS assessment identified gaps across all reviewed practices, including restricted access to cardholder data, secure handling of payment information, encryption, and password management.

Within the GDPR assessment, the organization has a breach-notification plan and established privacy procedures, but gaps remain in the protection and classification of customer data.

The SOC assessment indicates that data-integrity controls are in place, while user-access restrictions, sensitive-data confidentiality, and authorization controls require improvement.

These findings are consistent with the source risk assessment, which rates the organization's overall risk at 8 out of 10.

Recommendations and Remediation Priorities

Remediation should begin by maintaining the existing asset inventory and completing asset classification. Priority should then be given to implementing least privilege and separation of duties, strengthening password requirements, introducing centralized password management, and encrypting cardholder and PII/SPII data.

The organization should also establish tested backups and a disaster recovery plan, implement an intrusion detection system, and formalize a recurring maintenance schedule for legacy systems.

These measures address the highest-priority gaps identified in the assessment and would reduce exposure to unauthorized access, data loss, undetected threats, compliance-related penalties, and business disruption.